DPDP exposure report

What India's Digital Personal Data Protection framework requires, when each part binds you, and the order to close the gaps in. Position at 11 September 2026.

Start here: the deadline most people have wrong

The DPDP Rules 2025 were notified on 13 November 2025 and set an eighteen month phased timetable. A great deal of commentary reports that the substantive obligations land in November 2026. They do not.

November 2026 brings the consent manager framework into force. That is an ecosystem milestone. It creates a class of registered intermediary that individuals can use to manage consent across many companies at once. It does not, by itself, impose the notice, consent, security, breach and rights obligations on your business.

Those land on 13 May 2027, at the eighteen month mark. That is the date to plan against. From today it is roughly eight months.

One exemption worth checking first. Where an Indian business processes the personal data of people outside India under a contract with a company outside India, most of the Act's obligations do not reach that work. If your processing is outsourced delivery for an overseas client rather than service to Indian customers, your exposure may be narrower than this report assumes.

The three phases

Phase	Date	What commences
Phase 1	13 November 2025 In force	Definitions, and the establishment, composition and procedure of the Data Protection Board of India. Appeals lie to TDSAT. No operational duty on your business, but the enforcement machinery exists from this date.
Phase 2	13 November 2026	The consent manager framework. Consent managers must be companies incorporated in India and must register with the Data Protection Board of India. Relevant to you as a possible supplier, not as an obligation.
Phase 3	13 May 2027	Everything that binds you. Notice, consent, security safeguards, breach notification, data principal rights, retention and erasure, children's data, processor contracts and the additional obligations for significant data fiduciaries.

One live caveat. The government has been reported as considering a shorter compliance timeline than the eighteen months notified. Nothing has been formally amended. Plan against May 2027 and treat an earlier date as a risk rather than a certainty.

What Phase 3 actually requires

Stripped of the legal language, the obligations come down to seven things. The assessment you just completed maps to the first six.

Lawful basis is not only consent

The Act sets out specific legitimate uses that permit processing without asking each time: data a person voluntarily provided for a stated purpose and has not objected to, delivery of a state benefit or service, compliance with a court order or legal obligation, and response to a medical emergency or threat to public health. Narrow and enumerated, not a general route around consent.

Notice

A standalone notice, separate from your terms of service, in plain language, with an itemised description of the personal data collected and the specific purpose for each. A general privacy policy that says data is collected to improve the service does not satisfy this. It must be available in English or any language in the Eighth Schedule to the Constitution, which is a real operational commitment for a pan-India consumer product.

Consent

Free, specific, informed, unconditional and unambiguous, given by a clear affirmative action. No pre-ticked boxes. No bundling with unrelated terms. Withdrawal must be as easy as giving it, and processing must stop within a reasonable time after withdrawal.

Data principal rights, and a published contact

Access, correction, completion, updating, erasure, grievance redressal and nomination. The Rules set a maximum of ninety days to respond. You must also publish the contact details of the person who answers questions about your processing, and that applies to every data fiduciary rather than only the large ones.

Security safeguards

Reasonable security safeguards to prevent a breach, including access control, encryption and logging. This carries the highest penalty in the Schedule, and it attaches to not having taken the measures rather than to the breach itself.

Logs, one year minimum

Logs and traffic data retained for at least one year so an incident can be reconstructed after the fact. This sits inside the security safeguards duty rather than standing alone, which is why it is backed by the highest ceiling in the Schedule.

Breach notification, on two clocks

On becoming aware you must inform affected individuals and the Data Protection Board of India without delay, then file a detailed report with the Board within 72 hours. Awareness starts the clock, not the end of your investigation, and there is no materiality threshold: a breach affecting ten records carries the same duty as one affecting ten million. Separately, the CERT-In Directions of 2022 still require notifiable cyber incidents to be reported within six hours. A response plan built to 72 hours alone is already late on the first clock.

Retention and erasure

A defined reason for how long you hold data and a working process to delete it when that reason ends. Specified classes of large e-commerce, social media and online gaming intermediary face a three-year clock from last user engagement, with at least 48 hours notice to the individual before erasure.

Children and persons with disabilities

Verifiable parental consent before processing a child's data, with narrow exemptions for purposes such as healthcare, education and real-time safety. Tracking, behavioural monitoring and targeted advertising directed at children are prohibited outright. The same verifiable consent standard applies through a lawful guardian for a person with a disability who cannot consent themselves.

Where the data can sit

The most common question on this law is whether personal data of Indian customers has to stay on Indian servers. It does not, as a general rule. Section 16 of the Act and Rule 15 of the Rules work as a negative list: data may be transferred to any country except those the Central Government restricts by notification. No restricted list has been published.

Running your site, CRM or mail on infrastructure outside India is permitted. Three qualifications apply. The government may bar offshore transfer of specified categories for organisations designated as significant data fiduciaries, though no categories have been notified. Sectoral rules survive untouched, so RBI payment data localisation and the equivalent SEBI and IRDAI requirements still apply in those sectors. And this commences on 13 May 2027 with everything else.

The confusion persists because the 2019 and 2021 drafts of the Bill did propose mandatory localisation for sensitive data. It was dropped. A good deal of published commentary still describes a version of the law that was never enacted. What you do owe an overseas provider is a processor arrangement carrying your obligations, which is a contract question rather than a hosting one.

It is not only customer data

Most conversations about this law start and stay with customers. Two other places carry as much exposure and get almost none of the attention.

HR and payroll

Employees are data principals. The Act gives employers a shortcut: employment purposes, and safeguarding the employer from loss or liability, are a legitimate use that does not require consent. That covers most of what payroll, attendance and performance systems already do. It is not a blanket exemption. Security safeguards, accuracy, deletion when the purpose ends and a published grievance contact all still apply. An HR system holding PAN numbers, bank details, biometric attendance or insurance records attracts the same 72-hour clock and the same penalty ceilings as a customer database, and is often the least audited store in the company.

Vendor and supplier files

Most of a vendor file is company data and out of scope. But nearly every one also carries the name, phone number and email of the person you deal with, and KYC for a proprietor or partner in a smaller firm. The fix there is contact-detail hygiene: know which fields they are and apply the same retention you apply elsewhere.

A freelancer or individual contractor paid with TDS deducted is a different case. There is no company wrapper, so the entire record is personal data. Do not assume the employment ground that covers payroll stretches to someone not on your payroll; that is unsettled rather than safe. Two grounds hold up better: the freelancer voluntarily provided the PAN and bank details for the specific purpose of being paid, and retaining records for TDS filing is processing necessary to comply with a law in force. Retention resolves the same way, because the duty to delete gives way where another law requires keeping.

Vendors who process data for you

A payroll bureau, a background verification firm, a recruitment platform, a logistics partner handling delivery data. That is a processor question, not a vendor record question. The Act makes you responsible for what happens in their systems and requires a contract carrying security obligations equivalent to your own, not a purchase order silent on data. An MSA signed before this law existed usually says none of it, and renewal is the practical moment to fix that.

If you are designated a significant data fiduciary

Designation is made by the Central Government based on factors including the volume and sensitivity of data processed, risk to the rights of individuals, and risk to the sovereignty and integrity of India. The additional obligations are structural rather than procedural: a Data Protection Officer based in India, annual data protection impact assessments, annual independent audits, and due diligence on algorithmic software that could pose a risk to the rights of data principals. Certain categories of data may also be subject to government-specified restrictions, including localisation.

If designation is a realistic possibility for you, it changes your build timeline. These are hires and audit cycles, not policy updates.

What it costs to get wrong

The penalties are set out in the Schedule to the DPDP Act 2023 and attach to specific failures. They are ceilings, not typical outcomes, and the Data Protection Board of India decides each case after an inquiry.

Failure	Maximum penalty
Failure to take reasonable security safeguards to prevent a personal data breach	INR 250 crore
Failure to notify the Data Protection Board of India and affected individuals of a breach	INR 200 crore
Breach of the additional obligations on children's personal data	INR 200 crore
Breach of the additional obligations of a significant data fiduciary	INR 150 crore
Breach of any other provision of the Act or the Rules	INR 50 crore
Breach by a data principal of their own statutory duties	INR 10,000

Three points matter more than the headline number. The ceilings attach per failure, so a single incident handled badly can engage more than one line of the Schedule. Enforcement runs exclusively through that regulator, so exposure is regulatory rather than litigation driven. And penalties are paid into the Consolidated Fund of India rather than to the person whose data was affected: the Act gives no compensation route through the Board. Civil and consumer claims remain available, through the ordinary courts rather than through this law.

The order to fix things in

Most remediation plans fail because they start with the privacy policy. The policy is the output, not the input. This is the sequence that works.

1. Find the data

List every system holding personal data, what it holds, why, who can reach it and which vendor operates it. Include the spreadsheets and the shared drives. This is the step everything else depends on and the one most often skipped.

2. Fix the collection points

Rewrite notices as standalone, itemised documents. Rebuild consent capture as clear affirmative action with a withdrawal route that works. Collection points are where the evidence of compliance is created, so they come before the back end.

3. Build the rights process

A named owner, a route in, a defined internal path to find the data across systems, and a log. Ninety days is the ceiling, not the target.

4. Close the breach gap

A written incident response plan naming who decides, who notifies and within what time. Then run it once as a tabletop exercise. An untested plan is a document.

5. Set retention and make deletion real

Retention periods per category, and a process that actually deletes. Most organisations have the first and not the second.

6. Reach the vendors

Your processors carry your obligations in practice. Contracts need DPDP terms, and renewal dates are the practical opportunity to get them in.

Two things that are not real yet

The Data Protection Board of India is established but has not yet published decisions. Until it rules on cases, everyone is reading the text of the law rather than a body of precedent. That includes us. Where this report says what something is likely to mean in practice, that is a reading and not a settled answer.

Consent manager registration does not open until November 2026. Anyone offering you a registered DPDP consent manager service today is offering something that cannot yet exist in that form.

Sources

Government notifies DPDP Rules to empower citizens and protect privacy, Press Information Bureau, Ministry of Electronics and Information Technology, 14 November 2025. Release ID 2190014.

The Digital Personal Data Protection Act 2023, and the Digital Personal Data Protection Rules 2025, notified 13 November 2025. Ministry of Electronics and Information Technology, meity.gov.in.

Dates and figures verified 11 September 2026. This is a management document and not legal advice. Verify against the current gazette text before relying on any date here.